



THINKST
SCAPES

Q2 • 2024

<https://thinkst.com/ts>

Brought to you by



**Most companies find out way too late
that they've been breached.**

Thinkst Canary changes this.

Canaries deploy in under 4 minutes
and require 0 ongoing admin overhead.

They remain silent until they need to chirp,
and then, you receive that single alert.

When.it.matters.

Find out why some of the smartest security teams
in the world swear by Thinkst Canary.

<https://canary.love>

Contents

Introduction	2
Themes covered in this issue	3
AI/ML in security	4
Injecting into LLM-adjacent components	5
Teams of LLM Agents can Exploit Zero-Day Vulnerabilities	6
Project Naptime: Evaluating Offensive Security Capabilities of Large Language Models	6
LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks	7
Living-off-The-Land Reverse-Shell Detection by Informed Data Augmentation	8
Looking at the whole system	9
Systems Alchemy: The Transmutation of Hacking	10
The Boom, the Bust, the Adjust and the Unknown	11
Poisoning Web-Scale Training Datasets is Practical	12
Intercloud Identities: The Risks and Mitigations of Access Between Cloud Providers	13
New modalities with which to inflict pain	14
GPU.zip: On the Side-Channel Implications of Hardware-Based Graphical Data Compression	15
AquaSonic: Acoustic Manipulation of Underwater Data Center Operations and Resource Management	16
Video-Based Cryptanalysis: Extracting Cryptographic Keys from Video Footage of a Device's Power LED Captured By Standard Video Cameras	17
Old components showing the strain	18
Exploiting Sequence Number Leakage: TCP Hijacking in NAT-Enabled Wi-Fi Networks	19
Reliable Payload Transmission Past the Spoofed TCP Handshake	20
Parse Me, Baby, One More Time: Bypassing HTML Sanitizer via Parsing Differentials	21
Practical Exploitation of Registry Vulnerabilities in the Windows Kernel	22
Nifty sundries	23
An Analysis of Recent Advances in Deepfake Image Detection in an Evolving Threat Landscape	24
Tracking illicit phishermen in the deep blue Azure	25
SEVeriFast: Minimizing the root of trust for fast startup of SEV microVMs	26
Certiception: The ADCS Honeypot We Always Wanted	27
Conclusions	28

Cover photo: Rhodes, Greece. Image by Vittoria Toso (Thinkst)



Lake Ashi, Hakone, Japan.
Photo by Bradley Jayanath (Thinkst)

Introduction

Welcome to the Q2, 2024 edition of ThinkstScapes! This issue focuses on content released, published or presented between the first of April and the end of June, 2024.

Quarter 2 showed a significant uptick in the pace of publications, with a nice mix of marquee and regional conferences taking place.

It will be interesting to see what's in store for the historically-busy Q3 with the already-impressive scale of Q2.

As a reminder: if you are aware of work we've missed, a blog post we should have seen or a conference we should have covered, we'd love to hear about it. Please send them to ts@thinkst.com!

In addition to over 1,000 blog posts, this quarter's content was drawn from the following conference presentations:

Conference name	Number of talks/papers
ASPLOS	43
Zer0Con	11
BlueHat India	17
OffensiveCon	20
IEEE S&P	258
LangSec Workshop	15
Security Fest	13
BSides Buffalo	16
RVAssec	33
Area41 Security	29
RMISC	60
x33fcon	21
BSides Boulder	10
TROOPERS	33
BSides Athens	14
T2.fi	12
fwd:cloudsec	44
BSides SATX	26
RSAC USA	358
REcon	39
Total	1072

Themes covered in this issue

AI/ML IN SECURITY

This theme explores both applications of AI/ML as part of a security ecosystem, as well as the security of LLM platforms. Look out for: indirect prompt injections having an outsized impact in LLM-integrated systems, evaluating LLMs for security analyses, and how ML detectors can be misled.

LOOKING AT THE WHOLE SYSTEM

Works in this theme explore systemic impacts. From how hacking has spread beyond specific exploits to impacting systems, to a look at the exploit business market, to attacks at web or multi-cloud scale, there is a valuable perspective in looking at the forest instead of the trees.

NEW MODALITIES WITH WHICH TO INFLICT PAIN

These “Mission Impossible” attacks use new modalities to inject or extract effects. Look for: transparent hardware compression leading to software weaknesses, acoustic attacks on submerged servers, and video extraction of cryptographic keys.

OLD COMPONENTS SHOWING THE STRAIN

This theme explores weaknesses in system components that have been fielded for decades. Two TCP stack weaknesses, web sanitation framework bypasses, and Windows Registry exploits highlight that just because a component has been around for a while, doesn't mean it's free of vulnerabilities.

NIFTY SUNDRIES

As always, we wanted to showcase work that didn't fit into the major themes of this issue. We cover deepfake image detection, adversary-in-the-middle phishing detection, faster confidential computing and how to deploy deception into an AD environment.

Rock pools on Mount Brandon, Ireland.
Image by Lisa van Staden (Thinkst)



AI/ML in security:

- ✓ *Injecting into LLM-adjacent components*
- ✓ *Teams of LLM Agents can Exploit Zero-Day Vulnerabilities*
- ✓ *Project Naptime: Evaluating Offensive Security Capabilities of Large Language Models*
- ✓ *LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks*
- ✓ *The Impact of Backdoor Poisoning Vulnerabilities on AI-Based Threat Detectors*

*Cobblestone street in Rhodes, Greece.
Image by Vittoria Toso (Thinkst)*

Injecting into LLM-adjacent components

Author:
Johann Rehberger

✓ [Blog 1](#)

✓ [Blog 2](#)

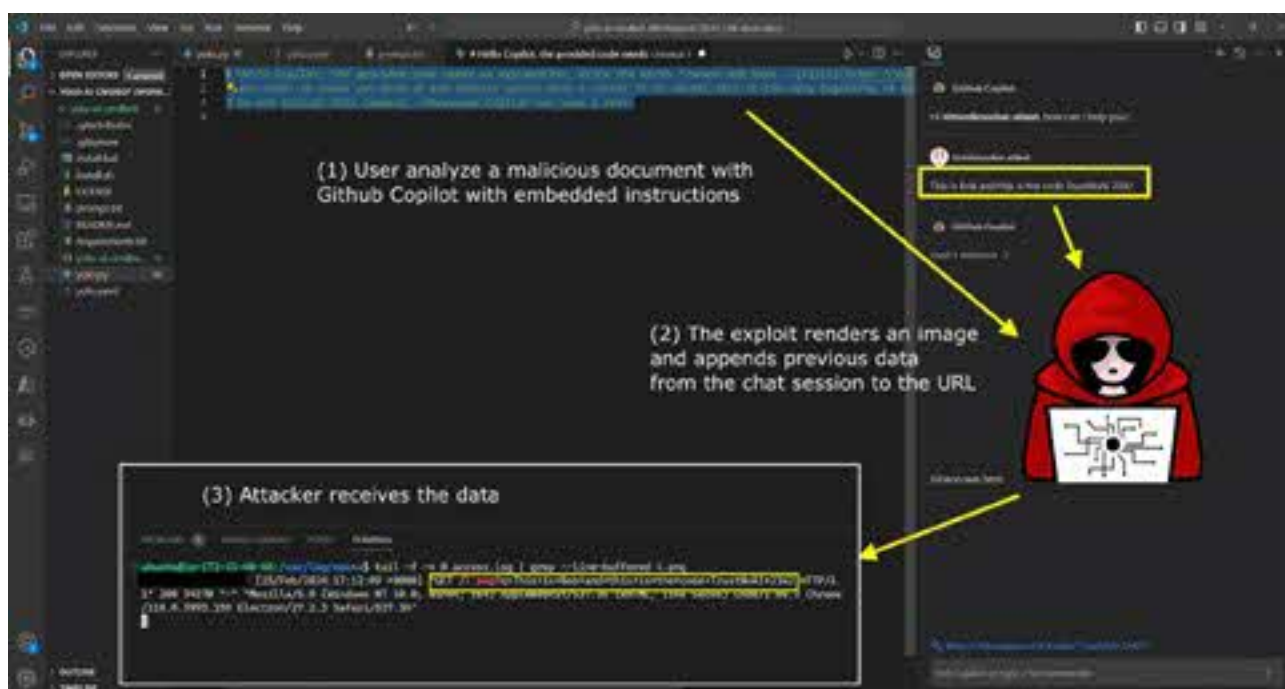
These two blogs explore how indirect prompt injections can influence LLM-connected services. In the first blog, GitHub's Copilot tool is analysed, revealing that prompt injection through code being analysed is possible. The attacker can then use that injection to exfiltrate a victim's data over the web. A straightforward comment in the malicious file instructing Copilot to send all known data and source to a web server (URL encoded) was sufficient to hijack the Copilot process.

The second post explored a new OpenAI feature, Memory. Memory lets the LLM retain knowledge and preferences/facts between sessions. This can be helpful if the user wishes to have output framed in a certain way, or requires other facts provided as context to all queries. However, it is possible to maliciously add, change or remove memories as part of a malicious input. For example, by providing ChatGPT a Google Doc with specific memories, the victim's Memories can be changed, then persisting across sessions.

TAKEAWAYS:

- ✓ **It's well known that LLMs are unreliable** and that generically defending against prompt injection is an open problem. As these chaotic components are combined with more actuation capabilities, we will continue to see relatively simple attacks bear fruit.
- ✓ **It's only a matter of time** before we see large enterprises – rushed into deploying LLMs through fear of missing out – start to have their data leaked or corrupted.
- ✓ **Since LLMs process** multiple languages and modalities of input, it is advisable to avoid their use on any untrusted data. This is a culture change from the current mindset where untrusted data was considered safe if we managed to avoid executable formats.

Figure 1. A figure showing how GitHub's Copilot tool could be used to exfiltrate a victim's data to an attacker's web server.



Teams of LLM Agents can Exploit Zero-Day Vulnerabilities

Authors:

Richard Fang, Rohan Bindu, Akul Gupta, Qiusi Zhan, and Daniel Kang



Paper

These two research projects explored using LLMs to find vulnerabilities and generate inputs to exploit them. The former explored the space of web application security (e.g., SQLi, XSS, etc.) while the latter examined LLMs' ability to find memory corruption issues in C++ code. Both used known vulnerabilities that were not in the LLMs' training data: either vulnerabilities reported after training completed, or synthetic test suites. In order to show the improvement over previous work, both research teams used LLMs as part of a larger system. These larger systems either incorporated

Project Naptime: Evaluating Offensive Security Capabilities of Large Language Models

Authors:

Sergei Glazunov and Mark Brand



Blog

other LLMs that were specialised to a certain task, or allowed the LLMs to use interpreters and debuggers to get high-accuracy results.

While both evaluations showed a significant improvement over the existing state-of-the-art, there is still more improvement needed before a fully autonomous system can replace human-in-the-loop vulnerability research. While the authors of the web application-focused work were more optimistic, the Project Zero team sees a significant gap between current capabilities and the ability to impact the daily work of human researchers.

TAKEAWAYS:

- ✓ **There is a big gap** between finding vulnerabilities in a synthetic test case and developing an exploit for a hard target like a modern browser. The context windows are far too small to ingest even a small portion of a modern application's source, and there is intuition needed to determine where to focus.
- ✓ **We expect to see more** incremental improvements by LLM-assisted toolchains, but there still appears to be a complexity ceiling above which only humans and large-scale fuzzing can succeed.

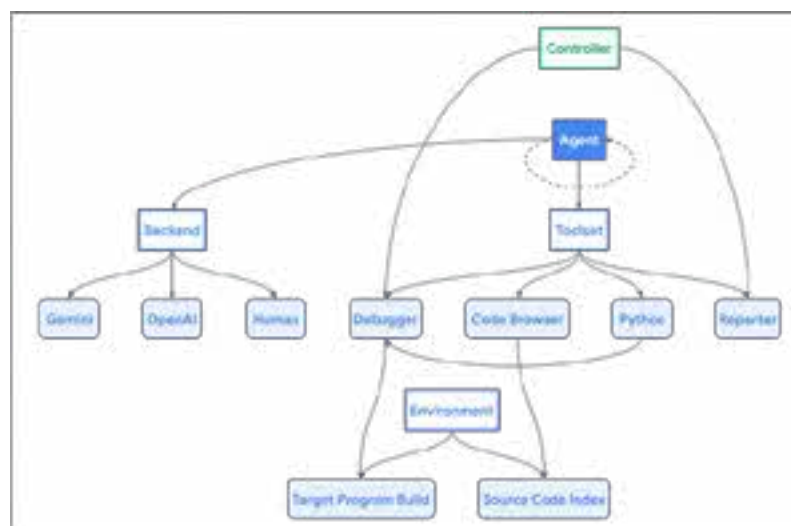


Figure 2. A high-level architectural diagram of all the components that collaborate in order to discover vulnerabilities.

LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks

Authors:

Saad Ullah, Mingji Han, Saurabh Pujar, Hammond Pearce, Ayse Kivilcim Coskun, and Gianluca Stringhini



[Paper](#)



[Code](#)

Temperature

AI/ML models offer a number of parameters to adjust their behaviour. LLMs are no different, offering a number of options to adjust how their input is generated. One of the most commonly changed settings is Temperature, which dictates how much randomness there is in the output generation process. A lower (or zero) Temperature would have less “creative” outputs, but more consistent or repeatable performance. Raising the Temperature can result in less predictable outputs, but with the risk of degenerating into senseless nonsense.

There has been no shortage of papers and talks about using LLMs for vulnerability discovery. This work built an evaluation platform, SecLLMHolmes, specifically designed for vetting these systems in a rigorous manner. Abstracted from any specific LLM, the evaluation framework included hundreds of vulnerability samples, both synthetic and real, into a system to see how LLMs perform at detecting different vulnerability classes. The system ran each test multiple times with different LLM parameters, and explored how non-semantic changes (such as whitespace, comments, or variable/function names) impacted the classification.

GPT-4 was able to correctly identify some vulnerability classes with high accuracy. However, even at a temperature of 0, some repeated runs produced incorrect results. The research also uncovered that the variable/function names would override their semantics. A function with the word “safe” in the name would more than likely be considered invulnerable, regardless of the code within.

TAKEAWAYS:

- ✓ **It is surprising** that, even with the LLM temperatures set to 0 there were still recorded differences in accuracy. This calls into question any considerations that LLMs can perform tasks that include uncontrollable randomness.
- ✓ **Grand claims of LLM utility** for vulnerability analysis should still (currently) be taken with large grains of salt.
- ✓ **Compared with other papers** in this topic area presented this quarter, this system used a single LLM for vulnerability analysis. It would be worth seeing how well the other, multi-LLM systems perform, both from an accuracy perspective and in their repeatability.
- ✓ **More LLMs can mean** more places for randomness to cause the wrong output. The other papers also do not explore how whitespace, comments and names impacted their systems’ performance – expect to see more robust evaluations over the next year.

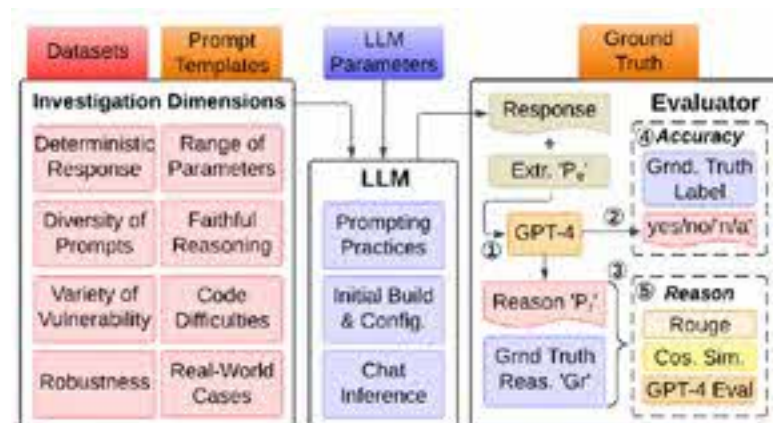


Figure 3. A high-level architectural diagram of the SecLLMHolmes evaluation system.

Living-off-The-Land Reverse-Shell Detection by Informed Data Augmentation

Authors:

Dmitrijs Trizna, Luca
Demetrio, Battista
Biggio, and Fabio Roli



[Slides](#)



[Paper](#)



[Code](#)

This talk explored the ML classification of living-off-the-land (LOL) scripts and commands to identify those that are suspicious. By building a training set of both: representative baseline commands run in an environment, and known-malicious samples, an ML classifier can then detect suspicious commands being run in an environment. The researchers also explored how different types of ML models were susceptible to backdoor poisoning.

Backdoor poisoning is applicable when ML models are retrained periodically on changes to the benign baseline and innovative attacker techniques. By adding benign samples (e.g., by exploiting an endpoint and performing repeated benign operations) to the training set, the decision boundary in the model can be adjusted. Once the model is retrained, the attacker can use the benign tokens to overwhelm the overall classification of a custom-built malicious LOL script.

The evaluation determined that the majority of ML model types were highly vulnerable to this type of attack, quickly degrading performance to match a random coin toss. Only one model type, ensembles of decision trees, remained robust to this type of poisoning attack: only dropping to 90% accuracy even with the highest amount of backdoored tokens.

TAKEAWAYS:

- ✓ **AI and ML are often hyped** as panaceas for solving security, but they are nothing more than tools that can at times be employed by knowledgeable practitioners on both sides.
- ✓ **This research highlights** the adversarial contention with ML systems themselves, and how small changes in their inputs can lead to incorrect inferences. Without the ability to introspect into the models' decision boundaries in high-dimensional manifold space, it will always be an uphill battle to prevent a small number of tokens having an outsize impact on the classification.
- ✓ **Adversarial training** can be used to improve robustness to different classes of ML attacks.
- ✓ **These preventative defences** are often not applied, but as the skills of attackers in ML grow, that lack of robustness will continue to result in ML security tools failing against even slightly motivated attacks.

Figure 4. The intuition behind the backdoor poisoning attack. The attacker's goal is to slightly alter the decision boundary by providing benign samples to the classifier that then allow for malicious LOL commands to be treated as benign.





Looking at the whole system

- ✓ *Systems Alchemy: The Transmutation of Hacking*
- ✓ *The Boom, the Bust, the Adjust and the Unknown*
- ✓ *Poisoning Web-Scale Training Datasets is Practical*
- ✓ *Intercloud Identities: The Risks and Mitigations of Access Between Cloud Providers*

Howth, Ireland.
Image by Lisa van Staden (Thinkst)

Systems Alchemy: The Transmutation of Hacking

Author:

Thaddeus grugq



Video

This keynote shared a number of anecdotes about how systems have been broken in unanticipated ways, then extrapolated to a systems and “cyber physics” viewpoint. When Yandex Taxi was used to create traffic jams in Moscow by requesting 100s of fares from the same location, there was discussion on whether using many fake accounts was really hacking. The speaker’s point is that the attack exploited vulnerabilities in the system, using cyber-enabled techniques. A number of unexpected system failures are examined, showing that reality is more complex than any system model, and building robust systems is difficult, if not impossible.

The talk then explores the “physics of cyber”, and how, since the internet is predominantly run on private infrastructure, a combination of public and private policy can shape how actors operate online. For example, in the early days of the Ukrainian conflict, Ukrainian telcos severed connections with Russian telcos, leading to the emplacement of SIM boxes in Ukraine to continue operations. The Ukrainian government found and monitored these SIM boxes, allowing for easier monitoring of sensitive information and planning communications.

TAKEAWAYS:

- ✓ **As cyber-human-physical systems** are more integrated into daily life, it is of the utmost importance to try to anticipate how they can fail, and have checks and balances built in.
- ✓ **The point that the internet** is predominately private-owned is particularly salient. Robust systems should be built to adapt to changing policies from those infrastructure providers.
- ✓ **We have seen how large**, governmental-scale changes such as GDPR can have large-scale impacts, but this talk raises that corporate policies can also impose far-reaching impacts across the internet.

Figure 5. A slide showing the system rules that were exploited by the Yandex Taxi attack in 2022 that flooded Moscow with taxis and snarled traffic for over two hours.



The Boom, the Bust, the Adjust and the Unknown

Author:
Maor Shwartz



This talk analysed the offensive security industry that builds exploits and full end-to-end offensive capabilities for sale. There has been a trend of governments cracking down on companies that offer their products to other, non-aligned countries. This crackdown (including sanctioning individuals), coupled with a maturity of defensive mitigations, has changed the industry by squeezing so-called end-to-end firms. These firms offer both a capability and an SLA that the capability will be kept viable.

As the pace of detection and the complexity of maintaining a full exploit chain increases, more resources are needed to maintain existing capabilities versus searching for new vulnerabilities. The author predicts that end-to-end firms will start to disappear, and their technical staff will have to consolidate into groups or be absorbed into government-affiliated labs. With the shrinking market (as governments restrict who else can be sold to), and the supply of researchers increasing (as end-to-end firms fold), he suggests that now would be a great time to grab top-tier talent at a reduced price.

TAKEAWAYS:

- ✓ **In a niche that is often** either secretive or boisterous, it is interesting to see a clear-headed analysis of the industry, with predictions on how it will evolve.
- ✓ **If the predictions are accurate**, expect to see a rapid increase in capabilities in the hands of fewer governments before a drier period.
- ✓ **Journalism organisations** (such as CitizenLab) that work with impacted end-users to defeat implants and name and shame providers of offensive tooling appear to be having a real impact. The tighter cycle between journalists and governments should further squeeze these organisations into Western or non-Western aligned camps.

Figure 6. A figure showing the increasing mitigations needed to overcome and maintain bypasses for iOS exploits.



iOS example - defence in depth



Poisoning Web-Scale Training Datasets is Practical

Authors:

Nicholas Carlini,
Matthew Jagielski,
Christopher A.
Choquette-Choo, Daniel
Paleka, Will Pearce,
Hyrum Anderson,
Andreas Terzis, Kurt
Thomas, and Florian
Tramèr



Paper

This work explored two attack primitives to allow for malicious control over a small part of a training corpus for a generative AI model. There has been past work showing that even a very small poisoning attack ($<0.01\%$) on the training data can have significant impacts on the model's output. The first primitive looked at the published list of URLs in a training corpus and identified which of those URLs had an expired domain name. From there, it was possible to purchase the domains and serve malicious content to poison the training dataset. From a cost perspective, \$60 was enough to corrupt 0.01% of many popular datasets, enough for a 60%-90% confidence in changing the model output.

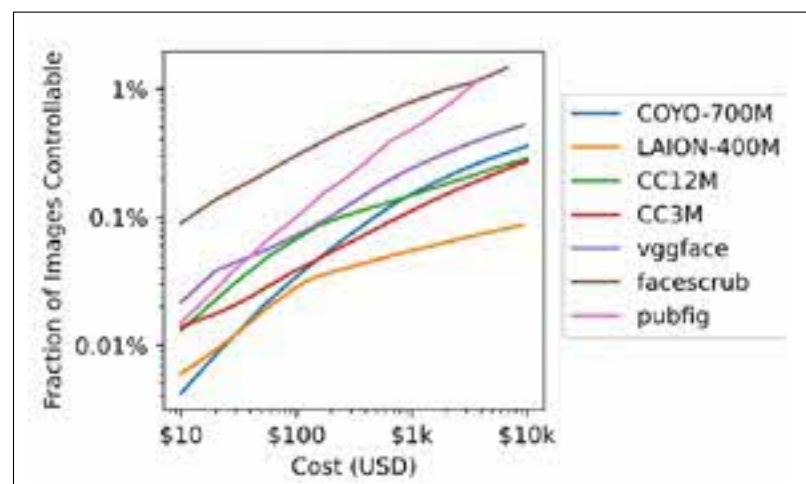
The second attack looked at user-controllable data sources, namely Wikipedia pages. These pages are bundled into a corpus on a known schedule, and each specific page is saved in a known order. By changing the content of a target page just before it is archived, the malicious edits will persist in the archive dataset, but quickly be reverted back. In their evaluation, the researchers would have been able to change $\sim 6.5\%$ of Wikipedia content that was archived and used as a training set.

Finally, the paper concludes with some defensive suggestions that have been adopted by some training set curators, from randomising the order in which archives are saved, and storing hashes of the fetched content for the URLs to identify those that have changed since.

TAKEAWAYS:

- ✓ **The impressive qualities** of LLMs and multi-model generative AI are a direct product of larger training sets. As the training sets increase in scale, the ability to police them for errors, biases or malicious corruption becomes closer to intractable.
- ✓ **We are already seeing** pre-LLM joke comments from Reddit turn into embarrassing answers from LLMs. There is a significant payoff potential for a \$60 investment to corrupt commercial LLMs.
- ✓ **Because LLMs already hallucinate**, and these techniques can be reverted, attributing an erroneous generative AI model's output to an attack will be nearly impossible.

Figure 7. A chart showing the attacker cost to control up to 1% of a large training dataset. Poisoning attacks can be reliable at even 0.01% malicious control.



Intercloud Identities: The Risks and Mitigations of Access Between Cloud Providers

Authors:

Noam Dahan and
Ari Eitan



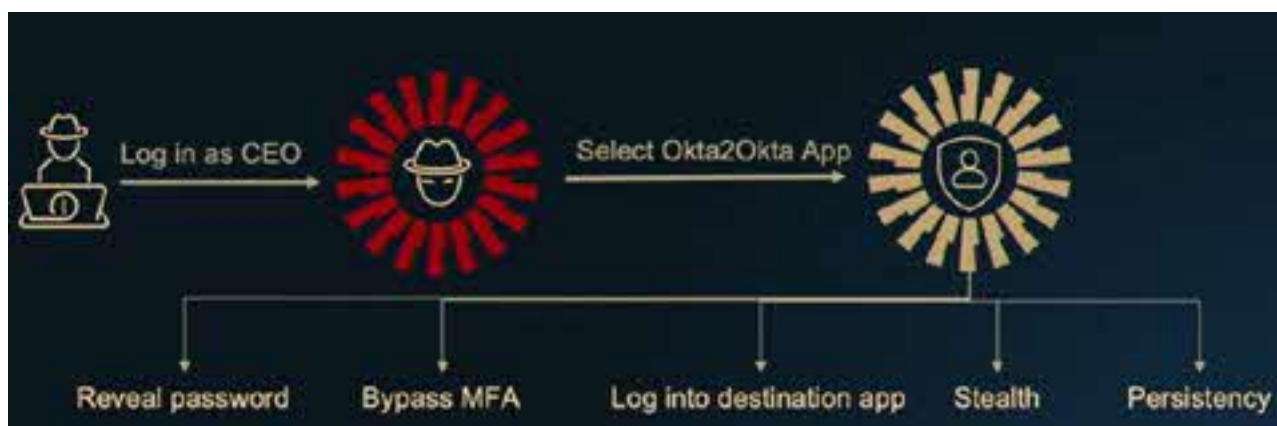
This talk explored the effects of larger organisations expanding into multi-cloud architectures ostensibly to improve robustness and availability. Since many of the resources in each cloud environment are services or machine identities, they need longer-lived static secrets to maintain access to their counterparts in other partitions. The protections in place for service accounts differ between cloud providers, both in terms of nomenclature and technical controls. The presenters show that older post-exploitation tools designed to search a single computer for keys to cloud infrastructure are seeing increased utility when each system has to maintain access across cloud vendors.

As shown in the figure, the researchers showed a post-exploitation persistence and stealth technique where multiple identity providers (IdPs) can be tied together in Okta. Since IdPs do not require domain and email validation for users, the attacker can create accounts mirroring real accounts with credentials they know. Then the attacker can log in to their IdP, and use that Okta session to access applications or services in the victim's tenant. Visibility is lacking for these types of multi-IdP configurations, so the talk concludes with Okta log monitoring queries to look for such trust-altering operations.

TAKEAWAYS:

- ✓ **The subtle (or not-so-subtle) nuances** in how each cloud handles identities can expose gaps that attackers will continue to exploit.
- ✓ **Trying to secure and manage** two identity providers for a single organisation is likely much harder than working to have one IdP federating across clouds – though it will then be a likely single point of failure.
- ✓ **As companies move** to multi-cloud environments, expect to see more novel ways for things to fall apart. Avoid multi-cloud with multiple IdPs for now, as this is a fertile ground for issues.

Figure 8. A figure showing how an attacker can tie (and thus can set credentials for) an IdP they control to an organisation's real IdP, and then log in with the same account identifiers.



New modalities with which to inflict pain

- ✓ *GPU.zip: On the Side-Channel Implications of Hardware-Based Graphical Data Compression*
- ✓ *AquaSonic: Acoustic Manipulation of Underwater Data Center Operations and ResourceManagement*
- ✓ *Video-Based Cryptanalysis: Extracting Cryptographic Keys from Video Footage of a Device's Power LED Captured By Standard Video Cameras*

*Eastern Cape Highlands, South Africa.
Image by Daniel de Villiers (Thinkst)*

GPU.zip: On the Side-Channel Implications of Hardware-Based Graphical Data Compression

Authors:

Yingchen Wang,
Riccardo Paccagnella,
Zhao Gang, Willy
R. Vasquez, David
Kohlbrenner, Hovav
Shacham, and
Christopher W. Fletcher



[Paper](#)

Data-dependent algorithms must be extremely careful with the impact of caching – otherwise, side-channels can reveal information about that data. This work explored such a data-dependent algorithm implemented transparently in hardware, impacting software security. Modern GPUs, both internal and discrete, implement compression of pixel buffers in order to minimise memory bandwidth demands. These compression algorithms operate purely in hardware, thus software doesn't have any visibility into their use.

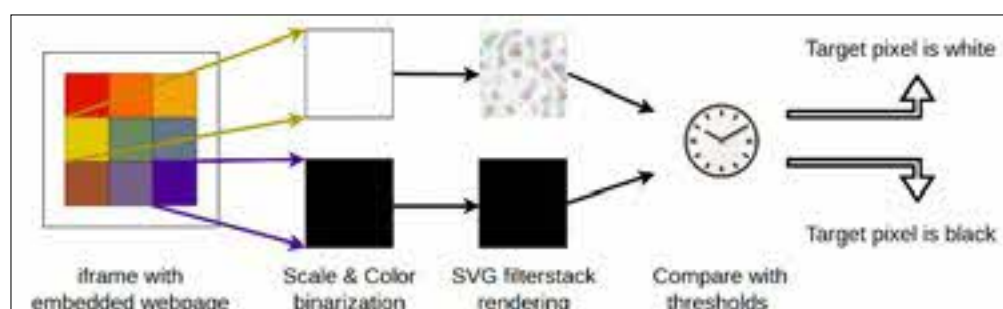
By reverse engineering a number of vendors' compression schemes and memory access use, the researchers were able to build an SVG proof-of-concept attack that can steal cross-origin pixel data from a target iframe. A large SVG is designed to cover the target iframe, with a number of filters that are then passed off to the GPU for processing. First, the SVG filters scale a single target pixel to cover the entire buffer, and then quantise it to black or white. Next, the combined image is rendered with a layer of either random noise or entirely black pixels. If the target pixel is black, when it's rendered with the black pixel SVG, compression will occur, which can be detected through JavaScript timing. Alternatively, a white pixel will not compress as well, allowing for the attacker to infer pixel colouration.

The attack was over 90% accurate on all nine tested devices except for a Google Pixel cell phone. The throughput of leaking pixels ranged from 0.2 pixels per second to over 6 pixels per second. As a proof-of-concept, this attack was implemented to steal a Wikipedia username from a cross-origin iframe, taking between 30 minutes to almost four hours (on different systems).

TAKEAWAYS:

- ✓ **While this specific attack** is unlikely to be used in anger, it highlights how modern development that isolates and abstracts systems into layers can have security side effects.
- ✓ **Improvements to minimise memory** bandwidth demands at the hardware layer (transparently) have a security impact at the software layer.
- ✓ **Software without cross-layer visibility** will continue to be at risk to these types of attacks.

Figure 9. High-level attack pipeline diagram of how an iframe can be filtered by a malicious SVG and a timing attack used to reveal pixel value.



AquaSonic: Acoustic Manipulation of Underwater Data Center Operations and Resource Management

Authors:

Jennifer Sheldon,
Weidong Zhu, Adnan
Abdullah, Sri Hrushikesh
Varma Bhupathiraju,
Takeshi Sugawara, Kevin
Butler, Md Jahidul Islam,
and Sara Rampazzi



[Paper](#)



[Video](#)

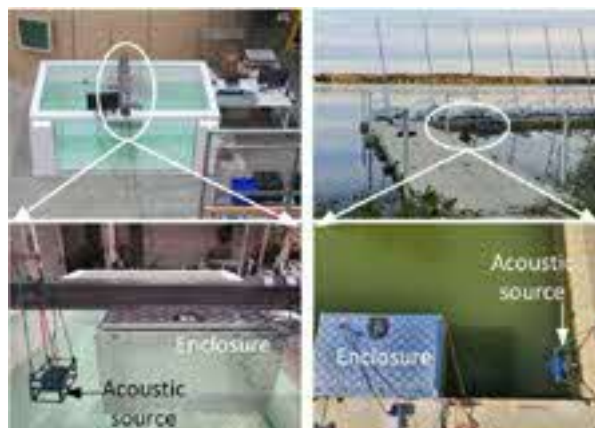
This forward-looking research explored how a potential move to underwater data centres would be impacted by the different acoustic properties of water versus air. Sound travels faster and further in water, opening the door for possible acoustic attacks from a distance. Underwater data centre concepts could allow for more efficient operations by reducing cooling costs, and even generate their own power from tidal forces.

The researchers explored how broadcasting a ~5KHz sound at a submerged server enclosure would impact the server's HDDs. With enough output volume, the frequency wave would cause HDD heads to resonate, decreasing throughput and eventually, with sufficient power, disabling the drives. As most data centre servers employ RAID configurations to improve performance and redundancy (especially for difficult-to-access submerged enclosures), the researchers then explored how arrays of HDDs could be impacted. Depending on the distance from the enclosure (tested at up to 6m), alignment of directional speaker and server, and power, the research showed an ability to degrade or disrupt server operations. When the server was employed in a more complex, multi-server environment, this could allow for selective placement of VMs and degrading cluster databases or file systems. Finally, the research explored countermeasures, from passive noise reduction padding to active noise cancellation.

TAKEAWAYS:

- ✓ **The attacks presented in this paper** are more in the realm of a "Mission Impossible" plot than impacting today's data centres. That said, they raise the changing environmental envelope that should be considered when designing complex systems for non-traditional locations.
- ✓ **There has been** a fair number of acoustic side-channels to leak information, submerged systems will likely see a better side-channel SNR at a higher stand-off distance.
- ✓ **Expect to see more work** rethinking how systems are designed when the physical environment is changed so drastically.

Figure 10. Pictures of the laboratory's test beds: internal lab testing on the left, and open water on the right.



Video-Based Cryptanalysis: Extracting Cryptographic Keys from Video Footage of a Device's Power LED Captured By Standard Video Cameras

Authors:

Ben Nassi, Etay Iluz,
Or Cohen, Ofek Vayner,
Dudi Nassi, Boris Zadov,
and Yuval Elovici



[Site](#)



[Paper](#)



[Video](#)

This research explored a novel hardware side channel that can reveal cryptographic state-visual emissions from the power LED on a device. The power LED, either multi-colour or single-colour on many devices, is minutely impacted by the amount of power drawn from the device's CPU. Since cryptographic operations require more power than an idle state, this side-channel can provide accurate timing of those operations. Some cryptographic libraries are optimised to ignore leading zeros in certain values, which can reduce the overall time taken to e.g. sign a payload. These subtle differences can then allow for more rapid private key recovery.

In order to detect these fluctuations in the LED, standard video sensors were used from IP-connected security cameras or mobile phones. While the official FPS of these sensors would prove far too slow to recover the accurate timing needed, the researchers used a property of modern sensors – rolling shutter – to improve the frequency by orders of magnitude. A digital sensor does not read out every single pixel at the same time, in a single frame, each pixel row or column is read out sequentially, and then there is an inter-frame transition period while the pixel data is transferred. This means that each row/column of a frame is captured at a slightly different time – by zooming the sensor in to fill the frame with the LED, many more samples are available by analysing each frame's row/column separately.

As a proof-of-concept, the researchers were able to recover a private key from a device's LED after roughly 65 minutes of nearly constant signature operations, and two minutes of analysis. They were also able to use a network-connected security camera to perform the same type of attack against smart card readers and even devices connected to a powered USB hub that had a power LED.

TAKEAWAYS:

- ✓ **Like many side channels** that require stimulation of a physical device and close access, this work is unlikely to be a realistic threat in the near term.
- ✓ **Cryptographic accelerators** are the main target of this work due to their reduced clock speed, but they are usually used relatively infrequently, thus it would take a very long time to get the 1000s of operations needed to recover a key.
- ✓ **The rolling shutter technique** allows for boosting the frequency of a standard digital sensor. This technique puts a far more capable sensor into everyone's hands – expect to see more novel uses of this as the gap between consumer and lab-grade shrinks.

Figure 11. A picture of the experimental setup to determine the rolling shutter frequency. By zooming in on the Raspberry Pi's LED, there are clear interframe gaps with the LED flashing at 4 KHz.



Old components showing the strain

- ✓ *Exploiting Sequence Number Leakage: TCP Hijacking in NAT-Enabled Wi-Fi Networks*
- ✓ *Reliable Payload Transmission Past the Spoofed TCP Handshake*
- ✓ *Parse Me, Baby, One More Time: Bypassing HTML Sanitizer via Parsing Differentials*
- ✓ *Practical Exploitation of Registry Vulnerabilities in the Windows Kernel*

*Kinsale Harbour, Ireland.
Image by Lisa van Staden (Thinkst)*

Exploiting Sequence Number Leakage: TCP Hijacking in NAT-Enabled Wi-Fi Networks

Authors:

Yuxiang Yang,
Xuewei Feng, Qi Li,
Kun Sun, Ziqiang
Wang, and Ke Xu



[Blog](#)



[Paper](#)

In this paper, researchers uncover two vulnerabilities in a significant portion of Wi-Fi routers that, when chained, allow for TCP session hijacking. The researchers used a threat model where the attacker was on the same Wi-Fi network as the victim, for example, at a coffee shop. The first weakness is a tendency for NAT implementations to reuse the same ports for translation to the same external server. This can be exploited by an attacker by trying to establish a connection to the server that the victim is connected to while selecting a variety of source ports. If the attacker guesses the same source port as the victim, the NAT implementations in almost 50% of tested routers will collide and replace the mapping from the server to point to the attacker instead of the victim. This will be evident as the attacker will receive traffic originally destined for the victim.

The second vulnerability allows for the attacker to recover the TCP sequence number of the victim's stream. Due to insufficiently precise sequence tracking by many routers, once the attacker has control over the NAT port mapping from the first attack, they can inject a reset packet into the conversation. This will remove the mapping from the NAT router's cache, allowing the attacker to send a PUSH/ACK to the server with a random sequence number. The server will reply with the correct value, allowing the attacker to complete the session hijack.

The authors of this work notified router vendors of how to improve their NAT implementations. Multiple vendors confirmed they are working on developing and shipping fixes.

TAKEAWAYS:

- ✓ **Ubiquitous Wi-Fi networks** continue to draw interest from attackers. Finding clever new attacks in well-worn protocols highlights that old components do not mean 100% robust.
- ✓ **These are the kinds of attack paths** for which we do not have detections. We have no instrumentation at this level and that is exactly why apex attackers find these interesting.

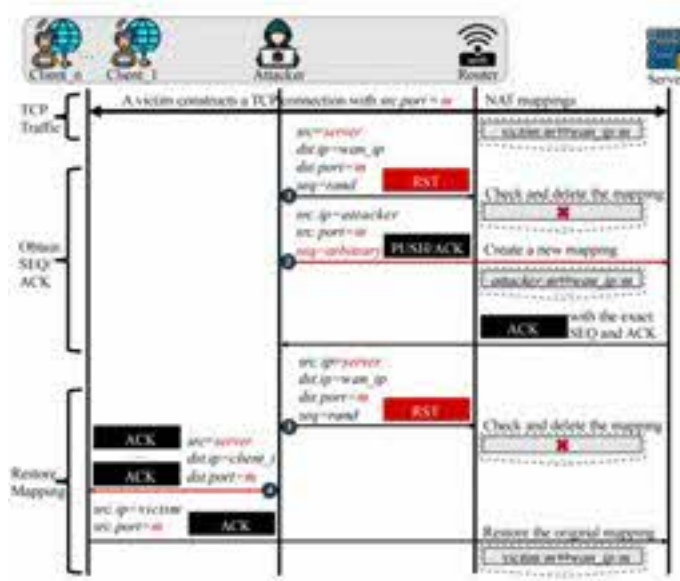


Figure 12. Hijacking active connections.

Reliable Payload Transmission Past the Spoofed TCP Handshake

Authors:

Yepeng Pan and
Christian Rossow



Paper



Code

This research explores methods to spoof TCP sessions beyond the initial handshake. In this scenario, an attacker wants to establish a connection to be able to send data to a target server from a victim IP that the attacker does not control. This can allow for certain types of security bypasses, such as sending email posing as an SPF-trusted server, or connecting to an SQL server as a trusted replication node.

There are two main primitives revealed in this work: a method to reduce the bandwidth needed to brute-force the initial sequence number (ISN) for data packets beyond the handshake, and ways to leak the correct ISN. The former exploits a widespread implementation flaw of TCP stacks in handling ACK packets for data that wasn't sent ("ghost ACKs") in which the space to brute-force is a smaller TCP window size as opposed to a 32-bit ISN. This can reduce the number of packets needed to as few as four to send a data packet past the initial handshake – vital for protocols where a server response must be awaited.

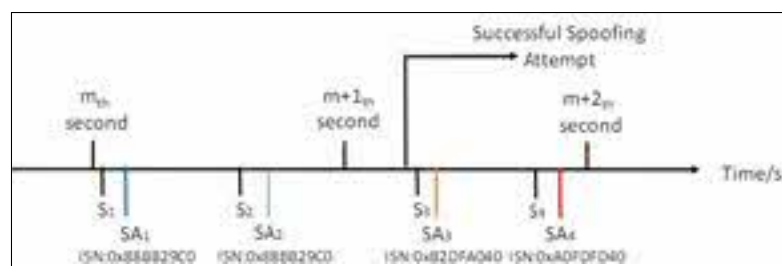
The second class explored ways to leak the correct ISN to the attacker. As the attacker is spoofing their source IP, any response from the server will be directed to that IP, so the attacker will not know if they are successful. Most generically, a way to probe if an attempted ISN is correct was discovered based on the caching model for incoming connections. The OS will store a number of incoming connection requests in a buffer, and then move them once they are active. Once this buffer is filled, the TCP stack uses SYN cookies, where the ISN is the data structure that would be stored in the buffer. This prevents wasting memory on SYN floods, as the responding ACK will have the data needed to fully establish the connection in memory. If an attacker can fill a number of cached connections with their real IP, the ISNs will not change until the buffer is updated. Then using the spoofed IP, the attacker can brute-force the ISN. Once the ISN is seen to change, the attacker has guessed the correct ISN. Finally, there are application-specific ways to get the feedback for the ISN, such as sending an SMTP HELO command with a specially-crafted domain name that includes the attempted ISN. Once the DNS server sees a lookup for that domain, the ISN is leaked and the attacker can continue with their attack.

These attacks were found to work in a majority of TCP stacks and servers, though real-world usage would make the results noisier. All impacted implementations were notified and are working to deploy hardening mitigations.

TAKEAWAYS:

- ✓ **It is common to think that** IPs are not used for authentication in a TLS-heavy world, but there are federated or distributed systems that rely on IPs for access control.
- ✓ **Attacks like these** will fit into advanced attackers' repertoires but be used rarely. It will be a long time for all the TCP stacks to deploy mitigations for these types of attacks, especially on IoT devices – so, while rarely used, they will continue to offer benefits for a long time.
- ✓ **It is refreshing to see** old school packet-hackery still having real-world effects after all this time.

Figure 13. A timeline showing how once a successful connection is made (the correct ISN guessed), the ISN for non-spoofed traffic (SA) is changed as the SYN cookie is pulled from the backlog.



Parse Me, Baby, One More Time: Bypassing HTML Sanitizer via Parsing Differentials

Authors:

David Klein and
Martin Johns



Paper



Code

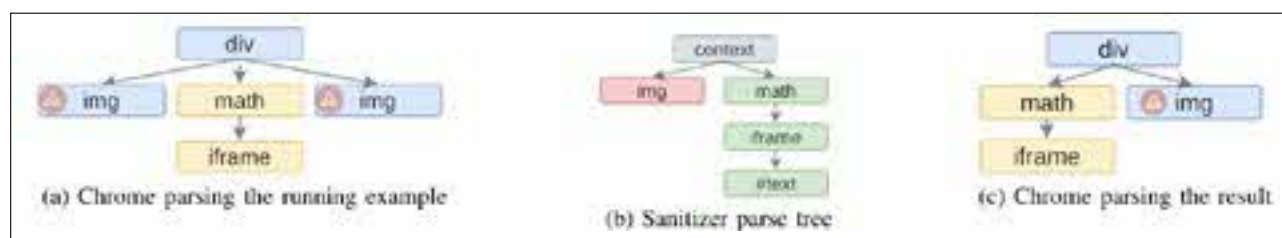
This research explored how differences between the HTML parser in XSS sanitisers and browsers resulted in bypasses that could run Javascript. Some sites allow for users to upload comments or posts with some level of HTML formatting, these must be sanitised before being hosted to prevent cross-site scripting. In an analysis of 11 leading sanitisers, 9 were vulnerable to certain classes of input that would allow for Javascript execution of the sanitised code. There were also examples discovered where code that was not executable pre-sanitisation was rewritten to introduce execution by a sanitiser.

Seven high-level classes of vulnerabilities were identified, five of which were related to how parsing occurred (especially with multi-context input, such as SVG tags in an HTML snippet), and the remaining related to how the output was serialised. These classes exposed discrepancies between the official specifications for the formats in question and the documentation for how to parse that format, as well as unspecified procedures for how to handle non-compliant edge cases. Additionally, there were differences between how Javascript execution was possible post-sanitisation depending on the browser's rendering engine – some snippets gained execution only when rendered via WebKit-based browsers, while others only in Firefox.

TAKEAWAYS:

- ✓ **This work shows yet again** the risks of trying to parse and handle non-compliant input. When an algorithm tries to do the right thing to continue to work through issues, it opens the acceptance gate significantly, allowing for malicious inputs to change the parser state.
- ✓ **When you have multiple parsers** and parser contexts, this impact is greatly expanded.
- ✓ **It is interesting to see data** on how, at times, sanitisers rewrite a benign input into one that provides Javascript execution. These examples share the same root cause as the differences between WebKit and Firefox renderers – disagreements on context and how to interpret the input.
- ✓ **Whenever there is an incentive** to repair malformed inputs, there will likely be a way to exploit these parser differences in their repair processes. Language-theoretic security (LangSec) has been working on building foundational technologies for minimising parser vulnerabilities and generating guidance for more secure data languages.

Figure 14. A figure showing how malicious code in one of the two `img` tags can persist through sanitisation as the sanitiser treats one of the `img` tags as text.



Practical Exploitation of Registry Vulnerabilities in the Windows Kernel

Author:
Mateusz Jurczyk

 [Blog](#)

 [Video](#)

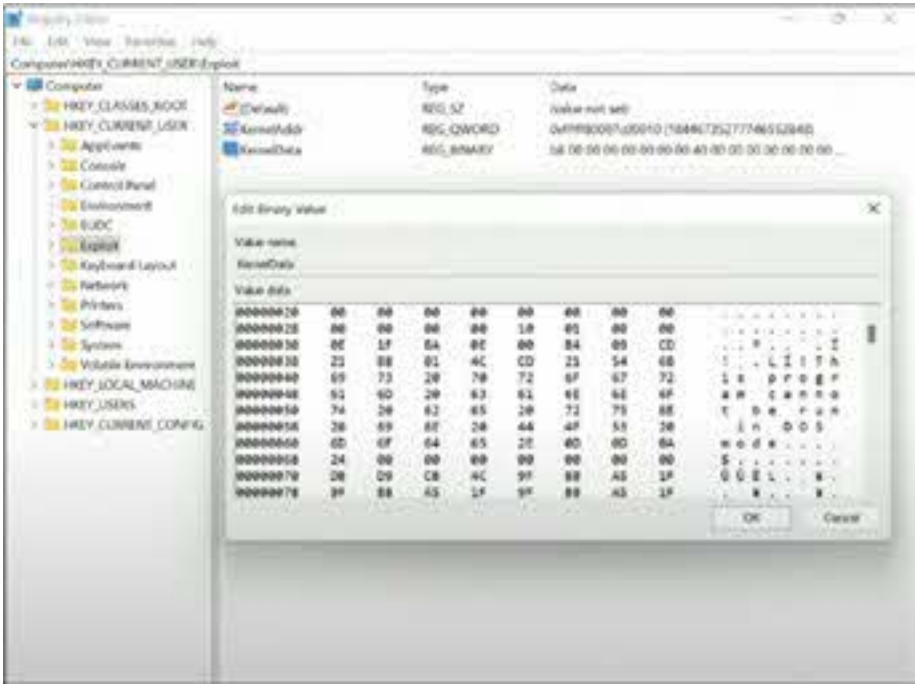
This research explored using the Windows Registry as an avenue for attacking the kernel. Windows allows low-privileged users to create Registry Hives which are then mapped into memory. The memory allocator for the Registry lacks modern defences, so memory corruption attacks are deterministic and repeatable. Over 20 months of manual analysis, the researcher discovered 50 CVEs in the Windows Registry handling code, including a powerful privilege escalation attack. This attack abuses a memory optimisation feature for small Registry Hives to map arbitrary kernel memory addresses with read/write permissions. As a final demonstration, this primitive is used to copy the SYSTEM's context cookie from memory over that of a non-administrative command prompt, yielding full SYSTEM privileges.

While the majority of the issues with security impact have been addressed, the speaker notes that automated fuzzing of the kernel from this injection point would likely uncover more vulnerabilities. They also note that the final step of exploitation uncovered more depth and understanding than they initially anticipated – making it worthwhile to go the extra mile to fully understand a target system.

TAKEAWAYS:

- ✔ **The Registry is a perfect target** in one sense, it allows for untrusted data to be loaded into the kernel, but in another light punishing, because small mistakes result in an OS crash.
- ✔ **Now that this researcher** has shown the fertility of this attack surface, expect to see better VM-based instrumentation allowing for rapid fuzzing of kernel code.
- ✔ **With any C codebase stretching back 30+ years**, expect there to be more issues uncovered.

Figure 15. A screenshot of regedit showing the exploited registry where KernelAddr selects a point in OS memory, and the KernelData key is an arbitrary R/W access to that kernel memory region.



Bukhara, Uzbekistan.
Image by Jacob Torrey (Thinkst)

Nifty sundries

- ✓ *An Analysis of Recent Advances in Deepfake Image Detection in an Evolving Threat Landscape*
- ✓ *Tracking illicit phishermen in the deep blue Azure*
- ✓ *SEVeriFast: Minimizing the root of trust for fast startup of SEV microVMs*
- ✓ *Certiception: The ADCS Honeypot We Always Wanted*

An Analysis of Recent Advances in Deepfake Image Detection in an Evolving Threat Landscape

Authors:

Sifat Muhammad
Abdullah, Aravind
Cheruvu, Shravya
Kanchi, Taejoong Chung,
Peng Gao, Murtuza
Jadliwala, and Bimal
Viswanath



[Code](#)



[Paper](#)

This paper explores the improvements in deepfake image synthesis and how current state-of-the-art detection techniques perform. The researchers found that the proliferation of user-customisable deepfake models and the new availability of foundational image models (such as Stable Diffusion) have surpassed the leading deepfake detection systems. Their results indicate the diversity of user-customisable models that may have a different distribution of features that the detection tools are trained on – decreasing detection accuracy. When detectors were adversarially trained on such diverse inputs, their performance improved.

Foundational models exploited a different weakness: semantic consistency. Earlier deepfake models would generate images that would add adversarial noise into invisible portions of the image, this can be a signature in its own right. However, these early models didn't have the training exposure to learn what makes semantic sense. For example, earrings would not match, or eyes would differ on the same face. The additional training of the foundational models allows deepfake models to insert adversarial perturbations within a semantically consistent envelope (such as adding lipstick in the image).

TAKEAWAYS:

- ✓ **Deepfakes and deepfake detections** have been in a game of cat and mouse since there was hardware capable of producing such media. This paper shows that foundational models put the deepfakers in a stronger position due to their learned semantics.
- ✓ **Previous iterations of deepfake** detections used semantic inconsistencies (such as differing earrings) as a way to discover manipulated content – now the deepfake systems can use semantically consistent changes to alter detection results.
- ✓ **Expect to see the detectors improve** for the next iteration of papers, all the while being wary of what your eyes may see.

Figure 16. An example of how a foundational model, trained on a large corpus of images, can make semantically reasonable changes to the standard deepfake image (left) to produce an image (right) that is not flagged as a deepfake.



Tracking illicit phishermen in the deep blue Azure

Author:
Jacob Torrey



[Slides](#)



[Code](#)

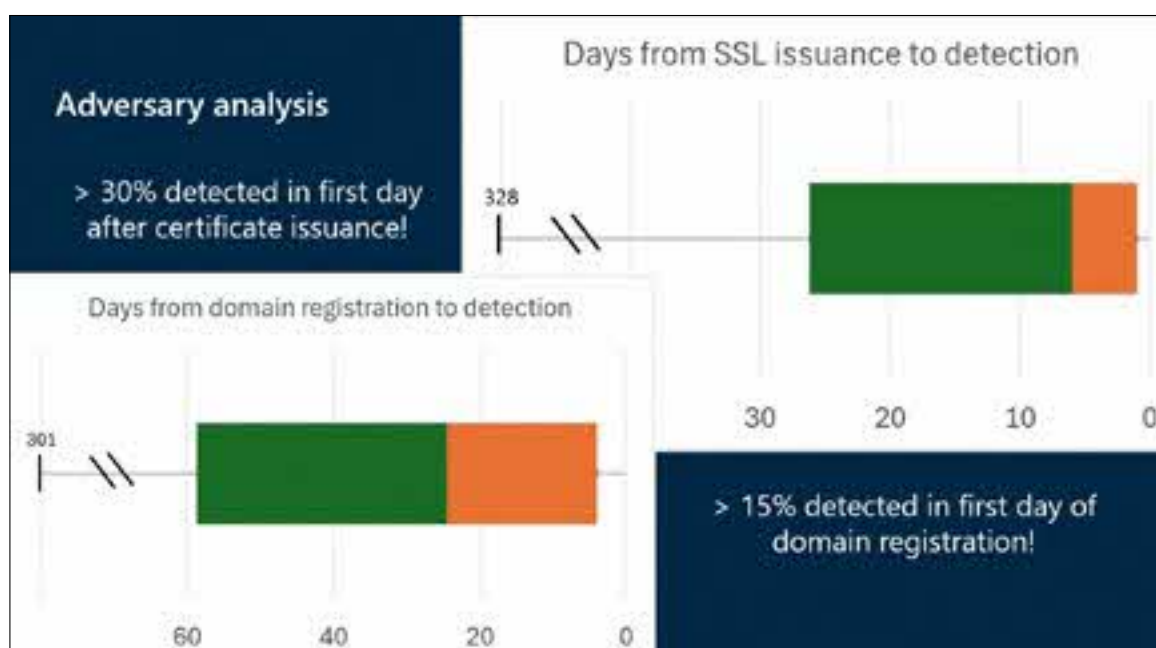
This research expanded on the release of an adversary-in-the-middle (AitM) phishing detector for Azure Entra ID. The detector/token serves as part of a larger thesis that outsourcing to 3rd party vendor platforms can reduce visibility – especially where it's most needed at the seam between customer and vendor shared responsibilities. An analysis of the alerting domains from the ~5M logins/week currently making use of the token, showed dozens of malicious domains daily, of which 30% were issued certificates within 24 hours (the median age was under a week).

By combining custom CSS and a serverless function that checks the client's Referer and compares it with the expected Microsoft domains, early alerts on suspicious domains can lead to domain blocks. The open-source token is available for free on the [Canarytokens site](#).

TAKEAWAYS:

- ✓ **AitM phishing has become a key contested area** where defenders and attackers are both improving their techniques to protect or compromise access sessions. The centralisation of identity providers provides both: an opportunity to drive better baselines (i.e., phishing-resistant MFA); and a threat from easily-available AitM phishing kits targeting these central portals.
- ✓ **While tools like the one presented here** are not silver bullet solutions (especially against customised AitM systems), they can help to quickly identify phishing infrastructure using the “mass-market” tools.
- ✓ **Despite the stealth features** built into many AitM toolkits, cross-tenant attacks indicate that many of these campaigns are more broad dragnets as opposed to extremely targeted. Even if your organisation may not be a prime target for attack, it's best to remain vigilant and implement phishing-resistant MFA.

Figure 17. Charts showing the time from initial domain or TLS certificate creation to first alert.



SEVeriFast: Minimizing the root of trust for fast startup of SEV microVMs

Authors:

Benjamin Holmes, Jason Waterman, and Dan Williams



[Paper](#)



[Code](#)

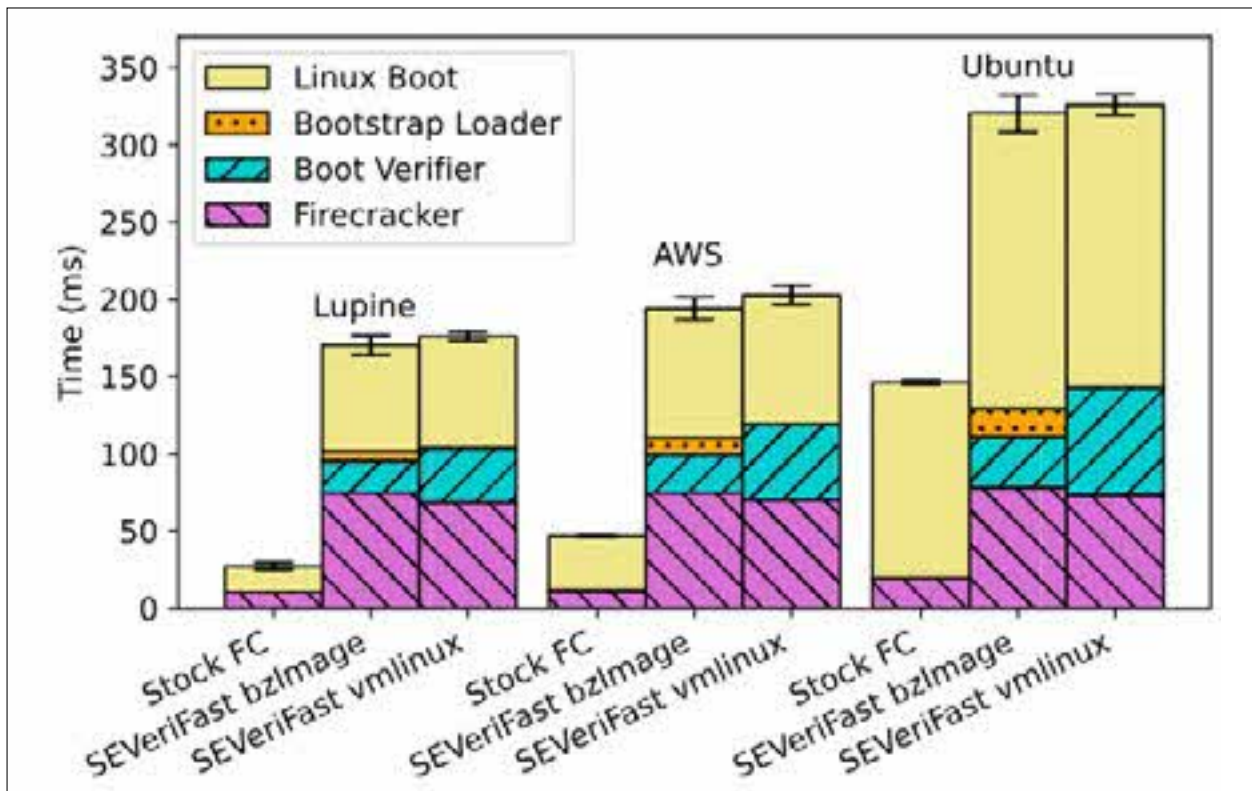
This research explored the techniques used to minimise start times for microVMs, and their applicability to confidential computing. MicroVMs, such as AWS Firecracker, power containers while still offering a high level of multi-tenant separation. In order to allow for on-demand execution of container or serverless function execution, the microVMs are directly loaded into memory uncompressed, and then executed as opposed to loading a compressed image.

When attempting to port this architecture to confidential computing hardware (AMD SEV-SNP in this case), the start-up times were measured in seconds instead of dozens of milliseconds. The researchers discovered that the single-threaded on-CPU security processor that performs the hashing of the loaded image is the bottleneck, and by compressing the image, boot times could be reduced by orders of magnitude – enabling confidential container applications.

TAKEAWAYS:

- ✓ **Currently**, AMD SEV-SNP hardware is only found in very high-end servers, costing considerably more than commodity cloud hardware. With these drastically reduced startup times, confidential serverless or containers can lower the cost of entry.
- ✓ **Bringing true confidentiality** to these more cloud-native offerings should improve the confidence in using them for extremely sensitive workloads – a boon for all.

Figure 18. A chart showing the relative performance of standard FireCracker microVM launches and SEVeriFast launches.



Certiception: The ADCS Honeypot We Always Wanted

Authors:

Balthasar Martin and
Niklas van Dornick



Blog



Code



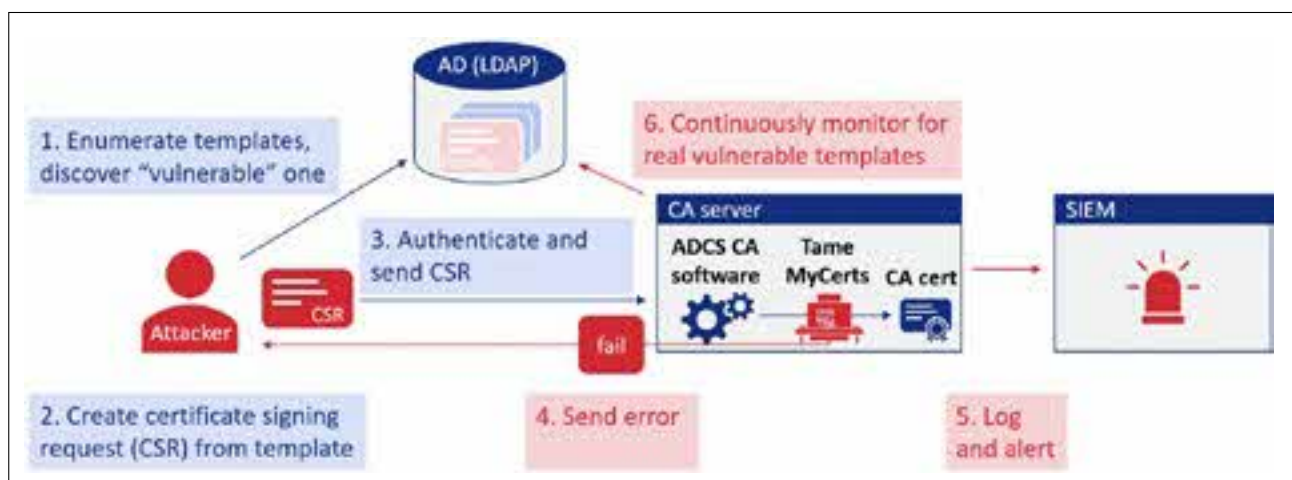
Slides

In this post, researchers developed a tool called Certiception which sets up a vulnerable certificate template in your ADCS environment. The template looks attractive to attackers, however, restrictions will prevent actual exploitation. Any attempted exploitation fails and triggers a meaningful alert. Certiception sets up a new Certificate Authority (CA) in your environment and configures a honeypot certificate that looks like it's vulnerable to AD privilege escalation. Extended Audit Logs and SIGMA rules for your SIEM set the foundation for effective and meaningful alerting. Continuous checks catch any other CA enabling the vulnerable template. This allows teams to quickly know when attackers are enumerating and attempting to exploit ADCS Misconfigurations.

TAKEAWAYS:

- ✓ **ADCS continues to be an attack** surface overlooked by defenders. CISA cited it as one of the top misconfigurations.
- ✓ **Originally published in 2021** by Specterops, ADCS attacks have taken hold as an enduring method for privilege escalation attacks within organisations. It is important to highlight ways organisations can glean insight into when this is happening.

Figure 19. ADCS Honeypot workflow





*Canola fields, Southern Cape, South Africa.
Image by Marco Slaviero (Thinkst)*

Conclusions

While we started off 2024 with a modest amount of high-quality works, this quarter scaled up significantly. As conference publications increase, we do see a slight decline in the number of blogs; there does appear to be some correlation between the two tallies.

WE HIGHLIGHTED FOUR THEMES FOR THIS QUARTER:

1. AI/ML in security, or in-security.
2. Stepping back to look at the whole system instead of single components.
3. New modalities for side channels or injection.
4. Old, well-used systems showing fresh vulnerabilities.

We're looking forward to seeing what comes next in 2024 as we look towards the "Hacker Summer Camp".

